

Análise de Processos Core do Windows

1. Introdução à Análise de Processos

A análise de processos consiste em validar a integridade do sistema operacional através da observação de metadados como **PID (Process ID)**, **PPID (Parent Process ID)**, **Image Path** e **Command Line**. Ferramentas como Gerenciador de Tarefas, Process Hacker e Process Explorer são essenciais para identificar técnicas de ocultação e persistência de adversários.

2. Inventário de Processos Críticos

Processo	PID Padrão	Processo Pai (PPID)	Caminho (Image Path)	Usuário
System	4	Nenhum / Idle (0)	ntoskrnl.exe (Kernel)	SYSTEM
smss.exe	Variável	System (4)	\System32\smss.exe	SYSTEM
csrss.exe	Variável	smss.exe (Encerrado)	\System32\csrss.exe	SYSTEM
wininit.exe	Variável	smss.exe (Encerrado)	\System32\wininit.exe	SYSTEM
services.exe	Variável	wininit.exe	\System32\services.exe	SYSTEM
svchost.exe	Variável	services.exe	\System32\svchost.exe	SYSTEM/Local/Network
lsass.exe	Variável	wininit.exe	\System32\lsass.exe	SYSTEM

winlogon.exe	Variável	smss.exe (Encerrado)	\System32\winlogon.exe	SYSTEM
explorer.exe	Variável	userinit.exe (Encerrado)	C:\Windows\explorer.exe	Usuário Logado

3. Indicadores de Comprometimento (IoC)

Para cada processo, os seguintes desvios devem ser considerados altamente suspeitos:

- **System:** Presença de um processo pai ativo ou múltiplas instâncias.
- **smss.exe:** Processo pai diferente do System (PID 4) ou execução fora da pasta System32.
- **csrss.exe:** Presença de um processo pai real (visto que o smss.exe mestre se encerra) ou execução como usuário comum.
- **services.exe:** Múltiplas instâncias ou PPID diferente de wininit.exe.
- **svchost.exe:** Ausência do parâmetro -k na linha de comando ou erros ortográficos (ex: scvhost.exe).
- **lsass.exe:** Múltiplas instâncias em execução simultânea (alvo comum para extração de credenciais como Mimikatz).
- **explorer.exe:** Execução a partir da pasta System32 (o correto é C:\Windows) ou conexões de rede TCP/IP de saída inesperadas.

4. Conclusão

O entendimento da "árvore genealógica" do Windows é a primeira linha de defesa em uma investigação de endpoint. Adversários frequentemente utilizam nomes de processos legítimos com erros sutis de grafia (*typosquatting*) ou manipulam o processo pai para evadir soluções de monitoramento. A validação do PID 4 constante para o System e a identificação de processos órfãos (cujo pai já se encerrou) são competências fundamentais para um analista de SOC.